Ethical Hacking Assignment 1

ITA14 Ethical Hacking ASSIGNMENT 1

NAME: **SHAIK THAHEER**

REG.NO: **192425347**

CODE: **ITA1434**

CO1

CO1: Apply the foundational concepts of ethical hacking, including the types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Assignment 1 Title : Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme

Scenario — University Authorized Security-Assessment Programme

A university is establishing an Authorized Security-Assessment Programme to test the security of its student portal, learning-management system, email service and campus network before a major upgrade. The programme must cover approximately 20 systems and 50 staff initially, but the framework is expected to remain usable as the programme grows to the whole university and begins to include external, third
party assessors.

The management has not yet fixed how ethical-hacking engagements will be governed. Testing may be requested by different departments, carried out by internal staff or external testers, and may touch systems that hold personal data. The team is concerned that an unstructured approach may lead to unauthorized access, legal exposure, damage to live systems, unclear scope or uncoordinated disclosure of discovered vulnerabilities.

You have been appointed as the Ethical-Hacking Governance Team. Your responsibility is not merely to describe hacking tools. You must investigate the requirements, design a complete engagement framework, construct reusable components and documents, integrate the different parts, validate the design through a walkthrough and defend the final framework using evidence.

The final framework must clearly distinguish between what is authorized, what is legal, and what is appropriate for the university. The team is expected to make governance decisions independently and justify why the framework is suitable for the given scenario. No live exploitation is performed; all work stays at the design, documentation and isolated-lab level.

Design Challenge

Create and validate an integrated ethical-hacking engagement framework for the university programme. The framework must define how an engagement is authorized, how scope and rules of engagement are set, how the relevant laws are respected, how different types of attackers are modelled, how discovered vulnerabilities are disclosed responsibly, and how an isolated lab is used where hands-on testing is required.

Your final design must be usable in practice and must demonstrate interaction among the selected components rather than treating each document or rule as an isolated example. Every major governance decision must be supported by evidence and a clear explanation of the trade-offs involved.

TASK 1 – Formulate the Enquiry and Framework Blueprint 4 Marks • Convert the scenario into a formal set of engagement-governance requirements. Identify the systems in scope, the stakeholders, the expected activities and the constraints.

• Create a framework blueprint showing how authorization, scope, legal compliance, threat modelling, lab testing and disclosure will cooperate in the proposed programme.

• Formulate at least four enquiry questions that your framework must answer, such as who authorizes a test, what is in scope, which laws apply and how findings are disclosed.

• Define at least five design criteria and use them as acceptance criteria for the final framework.

Evidence Expected

A requirements-to-governance blueprint, enquiry questions, design criteria and a clear rationale showing how the proposed framework addresses the scenario.

TASK 2 – Design a Hacker Threat Model and Classification 4 Marks • Design a classification of the types of hackers relevant to the university, such as white-hat, black-hat, grey-hat, script kiddie, hacktivist, insider and state-sponsored actors.

• Map each type to its motivation, typical capability and likely targets within the university. • Establish clear criteria and naming so that an actor can be classified consistently. • Demonstrate at least two alternative ways of classifying one borderline actor, then choose and justify the final classification.

Evidence Expected

A documented hacker threat model, classification criteria, a mapping table, rejected alternatives and a justified final classification.

TASK 3 – Create an Ethics and Code-of-Conduct Module 4 Marks • Define the ethical principles that govern an authorized engagement, such as written authorization, agreed scope, confidentiality, integrity, avoiding harm and honest reporting.

• Design rules or checks that help detect or prevent unethical actions during an engagement. • Construct scenario cases containing acceptable, borderline and unacceptable actions and show how the code of conduct responds to each.

• Explain how the module preserves trust and keeps the engagement lawful and professional.

Evidence Expected

A reusable code-of-conduct module, decision rules, scenario test cases and evidence that the rules separate acceptable from unacceptable actions.

TASK 4 – Construct a Legal-Compliance Mapping 4 Marks • Map the engagement to the relevant provisions of the Information Technology Act, 2000 on unauthorized access and data, and compare them with an international law such as the Computer Fraud and Abuse Act.

• Build a table of offences, obligations and penalties related to unauthorized access and data protection. • Connect each legal requirement to a specific control in the engagement framework. • Decide and justify which legal requirements apply when a test touches systems that hold personal data.

Evidence Expected

A legal-compliance mapping, an offences-and-penalties table, the controls linked to each requirement and a justified conclusion on which laws apply.

TASK 5 – Create a Scope and Rules-of-Engagement Document 4 Marks • Design a scope and rules-of-engagement (RoE) document that defines in-scope and out-of-scope systems, testing windows, permitted and prohibited techniques and escalation paths. • Create rules for recording and verifying the written authorization behind each engagement. • Establish clear naming and boundaries so that an out-of-scope request can be detected. • Construct at least one transformation of the RoE into a pre-engagement checklist.

Evidence Expected

A complete RoE document, authorization-verification rules, scope boundaries and a derived pre engagement checklist.

TASK 6 – Build an Authorization and Disclosure Layer 5 Marks • Create an authorization workflow covering the request, approval, written sign-off and recording of each engagement.

• Design a responsible (coordinated) disclosure process with a reporting format, remediation window and timeline, and compare it with full disclosure and bug-bounty approaches.

• Develop operations for logging approvals and status updates and for deciding when disclosure may proceed.

• Create rules for choosing between coordinated and full disclosure for a given finding. • Demonstrate that this layer interacts correctly with the rules-of-engagement and legal-compliance components.

Evidence Expected

An authorization workflow, a responsible-disclosure process, logging and decision operations, disclosure rules and evidence of interaction with the other components.

TASK 7 – Design an Isolated Ethical-Hacking Lab 5 Marks • Design a safe, isolated lab using a Kali Linux machine and one or more authorized target machines on a host-only network with reserved

addresses such as 192.168.56.0/24.

• Specify the components, roles and connectivity of the lab and the steps used to record its configuration.

• Develop at least two operations, such as verifying connectivity between the machines and recording the lab setup.

• Construct a small comparison between a host-only and a NAT lab network and justify the chosen design.

• Explain how the lab keeps all testing authorized and contained within the isolated environment.

Evidence Expected

An isolated-lab design, a component and connectivity specification, verification operations, a comparison of network options and a justified final lab model.

TASK 8 – Develop a Reusable Document Library 4 Marks • Create a minimum of four reusable engagement documents supporting the framework, including at least one authorization form and one finding report.

• Use sensible default fields where appropriate and explicitly design the content of each document. • At least one document, such as the finding report, must produce a structured output that integrates with another component of the framework.

• Create test entries that demonstrate valid, boundary and invalid inputs and document the expected result.

Evidence Expected

A reusable document library, documented fields, a structured report output, test entries and evidence of integration with the framework.

TASK 9 – Integrate, Test and Refine the Framework 4 Marks • Integrate the components created in Tasks 2-8 into one coherent engagement framework. • Construct a realistic walkthrough of an authorized assessment from request and authorization, through testing in the isolated lab, to responsible disclosure.

• Design systematic test cases covering missing authorization, out-of-scope requests, legal conflicts and delayed disclosure.

• Record the problems encountered during the walkthrough and show how the framework was refined to address them.

Evidence Expected

A reproducible integrated framework, a workflow walkthrough, systematic test cases, refinement evidence and a final corrected framework.

TASK 10 – Create a Scalability and Governance Evaluation 4 Marks • Construct scenarios representing a small programme (one department) and a large programme (the whole university with external assessors), with the number of systems and testers involved. • Experiment with at least three important processes from the framework and record meaningful measures such as approval

turnaround, scope coverage or the number of steps.

• Create a comparison table and at least one suitable chart or structured visualization. • Use the evidence to refine the governance of the framework rather than simply reporting the measures.

Evidence Expected

A reproducible evaluation setup, a comparison table, a visualization, an interpretation and evidence of at least one governance refinement based on the results.

TASK 11 – Defend the Framework Under a Changed Requirement 4 Marks • Changed requirement: the university now runs continuous and third-party assessments with stricter data-protection rules and a shorter disclosure timeline, and needs the framework to remain easy to govern and extend.

• Create a revised version of your framework by deciding which components should be retained, modified, replaced or redesigned.

• Construct at least one new or modified component that directly addresses the changed requirement and show how it integrates with the existing framework.

• Defend the final framework using evidence from your walkthrough, scalability evaluation, legal mapping and disclosure process.

• Identify at least two trade-offs or limitations that remain in your final design and propose future improvements.

Evidence Expected

A revised framework, demonstrated adaptation, an evidence-based defence, explicit trade-offs and a clear explanation of how the final design satisfies the changed requirements.

MARK DISTRIBUTION

Task	Marks
TASK 1 – Formulate	4
TASK 2 – Design	4
TASK 3 – Create	4
TASK 4 – Construct	4
TASK 5 – Create	4
TASK 6 – Build	5
TASK 7 – Design	5
TASK 8 – Develop	4
TASK 9 – Integrate,	4
TASK 10 – Create	4
TASK 11 – Defend	4
TOTAL	50

DECLARATION

I declare that this assignment is prepared for academic purposes and presents a governance design for an authorized university security-assessment programme. The framework is a design and isolated-lab exercise only. It does not authorize testing of any live university system, third-party service, account, network or device.

ABSTRACT

This assignment proposes an integrated governance framework for a university that plans to assess approximately 20 systems and 50 staff initially, with a path to university-wide and third-party assessments. It joins written authorization, asset scope, rules of engagement, legal review, threat modelling, ethical conduct, isolated-lab validation, coordinated vulnerability disclosure, reusable documents and programme evaluation. The framework deliberately separates three questions: whether an activity has been authorized by the correct owner, whether it is lawful under applicable law, and whether it is appropriate and proportionate for the university. A positive answer to one question does not automatically answer the other two.

1. INTRODUCTION AND PROGRAMME CONTEXT

The university operates a student portal, learning-management system (LMS), email service and campus network. These systems support teaching, assessment, identity, communication and administration. A security assessment can identify weaknesses before a major upgrade, but uncoordinated testing can interrupt classes, expose student or staff data, affect third-party services or create legal risk.

1.1 Programme assumptions

Item	Initial design assumption
Environment	Approximately 20 systems and 50 staff; later expansion to all university systems and external assessors.
System categories	Student portal, LMS, email, campus network, identity services, supporting databases, web applications, endpoints and approved infrastructure.

Data	Student and staff identifiers, contact details, academic records, authentication data and operational logs may be present.
Assessment model	Risk-based, time-boxed, written authorization; no live exploitation in this assignment.
Testing location	Hands-on demonstrations occur only in an isolated host-only virtual lab using synthetic data.
Governance owner	A Security Assessment Governance Team (SAGT) coordinates approvals, legal review, scope, records and disclosure.

1.2 Three separate gates

Gate	Question	Required evidence
Authorization	Has the owner with delegated authority explicitly approved this exact activity, target and time window?	Signed authorization, owner approval, asset identifiers, tester identities and expiry.
Legality	Does the activity comply with applicable law, contracts, privacy and regulatory duties?	Legal/privacy review, data handling plan, processor terms and jurisdiction check.
Appropriateness	Is the activity necessary, proportionate, safe and aligned with university operations?	Risk assessment, safe method, change window, stop conditions and service-owner agreement.

A test proceeds only when all three gates pass. A signed form cannot legalize an otherwise unlawful act; legal permissibility does not create university permission; and an authorized test may still be inappropriate if it creates avoidable harm.

2. TASK 1 – FORMULATE THE ENQUIRY AND FRAMEWORK BLUEPRINT (4 MARKS)

2.1 Formal governance requirements

ID	Requirement	Governance response / evidence
R1	Only approved people may test approved assets.	Named tester list, owner sign-off, authorization ID and expiry.
R2	Targets and exclusions must be unambiguous.	Asset register with hostnames, IPs, URLs, environments and third-party dependencies.
R3	Testing must not endanger availability or confidentiality.	Risk rating, maintenance window, rate limits, backup/rollback and stop conditions.
R4	Personal data must be minimized and protected.	Synthetic data preference, masking, no bulk extraction, encrypted evidence and retention schedule.
R5	Internal and external assessors follow the same controls.	Contract clauses, NDA, named personnel, access expiry, supervision and audit rights.
R6	Findings must be triaged and disclosed consistently.	Finding ID, severity, owner, remediation target, coordinated disclosure log.
R7	The programme must scale.	Central register, reusable templates, role-based approvals and periodic metrics.

R8	Testing must be reproducible and auditable.	Versioned RoE, evidence log, lab configuration record and closure report.

2.3 Enquiry questions

1. Who has authority to approve an assessment, and what evidence proves that authority?
2. Which exact assets, environments, identities, dates and techniques are included or excluded?
3. Which Indian laws, privacy obligations, contracts and foreign laws may apply to the activity?
4. How will the programme model likely attackers and prioritize threats to university assets?
5. How are findings classified, reported, remediated and disclosed without exposing students or staff?
6. How can hands-on testing be demonstrated safely without reaching live systems?

2.4 Design criteria and acceptance tests

Criterion	Acceptance test
Authorization completeness	No engagement can enter 'Approved' without owner, approver, tester, asset list, dates and signed RoE.
Scope precision	Every target has a unique asset ID and explicit environment; unlisted targets are blocked.
Legal/privacy assurance	Every engagement records legal/privacy review outcome and data-handling controls.
Safety and containment	High-risk techniques are prohibited by default; lab traffic is isolated and verified.
Disclosure accountability	Every finding has an owner, severity, due date, status and disclosure decision.
Auditability	Approvals, scope changes, test events and disclosure decisions are timestamped.
Scalability	Templates and role-based workflow support 20 assets/50 staff and can expand without redesign.

3. TASK 2 – HACKER THREAT MODEL AND CLASSIFICATION (4 MARKS)

3.1 Classification method

Classify an actor by observable behaviour, authorization status, intent, capability and target—not by a label alone. Use the following decision order: (1) Was there explicit permission for this exact action? (2) Was the action within scope? (3) What was the primary intent? (4) What capability and resources were demonstrated? (5) What target was selected? Record uncertainty rather than guessing identity.

Type	**Motivation**	**Typical capability**	**Likely university targets**
White-hat	Improve security under permission.	Professional testing, reporting, controlled validation.	Portal, LMS, email, network—only within signed scope.
Black-hat	Financial gain, theft, disruption or coercion.	Credential theft, malware, exploitation, data exfiltration.	Student records, payroll, email, identity systems.
Grey-hat	Curiosity, recognition or mixed motives; may act without permission.	Moderate to advanced discovery; may cross boundaries.	Public portal, exposed services, misconfigured storage.
Script kiddie	Entertainment, status or opportunism.	Low skill; relies on public scripts and tools.	Public-facing login pages, Wi-Fi, exposed services.
Hacktivist	Political, social or ideological cause.	Defacement, leaks, DDoS or coordinated campaigns.	Public website, email, public communications.
Insider	Grievance, profit, coercion or careless behaviour.	Legitimate access misused; knowledge of internal processes.	Student database, staff mailboxes, shared drives.
State-sponsored actor	Espionage, strategic access or influence.	Well-resourced, persistent, stealthy operations.	Research data, identity infrastructure, executive email.

3.3 Borderline actor analysis

Scenario: a technically skilled individual notices an exposed university portal endpoint, sends a small number of requests without permission, confirms that a record identifier can be changed, does not download records, and privately emails the university asking for recognition.

Alternative classification	Reason supporting it	Why it is not the final label
White-hat	The person reports the weakness and does not appear to steal data.	Rejected: good intent and private reporting do not create prior authorization.
Black-hat	The person intentionally accessed a system without permission.	Too strong without evidence of malicious intent, theft, disruption or extortion.
Grey-hat	Unauthorized probing with a claimed helpful or recognition-seeking motive.	Best fit based on current evidence; label is behavioural, not a legal verdict.

3.4 Threat priorities

- Highest impact: insider misuse and credential compromise because legitimate access can reach sensitive records.
- High likelihood: commodity scanning and password attacks against public-facing services.
- High consequence but lower frequency: persistent, well-resourced actors targeting research or identity infrastructure.
- Control implication: prioritize identity protection, logging, least privilege, backups, network segmentation and rapid incident escalation.

4. TASK 3 – ETHICS AND CODE OF CONDUCT (4 MARKS)

4.1 Reusable code of conduct

7. Written permission first: do not test until the signed authorization and current RoE are recorded.
8. Stay within scope: use only approved assets, accounts, techniques, dates and source IPs.
9. Least harm: choose the least intrusive method that answers the agreed question; avoid denial-of-service, destructive actions and persistence.
10. Protect confidentiality: do not browse, copy, retain or disclose personal data unless specifically necessary and legally approved; use synthetic or masked evidence.
11. Preserve integrity: do not alter production records, install backdoors, change controls or conceal activity.
12. Be honest: report limitations, false positives, unexpected effects and mistakes promptly.
13. Respect people and services: no social engineering of students/staff unless expressly approved; no harassment, impersonation or unauthorized password collection.
14. Stop when uncertain: pause on scope ambiguity, unexpected sensitive data, service instability or suspected real compromise.
15. Secure evidence: encrypt it, restrict access, log handling and delete it at the approved retention deadline.
16. Disclose responsibly: use the designated reporting channel and do not publish identifying details before the disclosure decision.

4.3 Scenario test cases

Scenario	Classification	Code response
Tester runs an approved low-impact configuration check during the approved window.	Acceptable	Proceed, log action and retain minimal evidence.
Tester discovers a neighbouring host not listed in the RoE and considers scanning it.	Borderline request; action prohibited	Do not scan. Record observation and seek written scope amendment.

Tester sees a student record while validating access control and captures only a masked screenshot after owner approval.	Acceptable only if approved and minimized	Mask identifiers, encrypt evidence, log access and follow retention rule.
Tester downloads a full student database to prove impact.	Unacceptable	Stop, secure incident evidence, notify SAGT/privacy/legal and assess breach obligations.
Tester discovers a service instability and continues to complete the test plan.	Unacceptable	Stop immediately; invoke emergency contact and rollback process.
Tester publishes an unpatched vulnerability with screenshots naming students.	Unacceptable	Escalate; request takedown/containment and follow coordinated disclosure.

4.4 Trust and professionalism

The code of conduct gives the university, staff and students predictable protections. It also protects assessors by defining permitted actions and a stop-work route. Signed scope, minimum data access, independent legal review and traceable reporting reduce ambiguity and discourage both deliberate misconduct and accidental overreach.

5. TASK 4 – LEGAL-COMPLIANCE MAPPING (4 MARKS)

This is an academic compliance map, not legal advice. The university must obtain advice from Indian counsel before each real engagement. The controlling facts include where the system and tester are located, who owns or operates the system, what data is processed, the contract chain, and whether any foreign system or person is involved.

5.2 Offences, obligations and penalties (selected provisions)

Provision	**Conduct / obligation**	**Stated consequence (high-level)**

s.43	Unauthorized access, copying, damage, disruption and related acts.	Compensation to the affected person; statutory text provides civil liability.
s.66	Dishonest or fraudulent acts described in s.43.	Up to 3 years' imprisonment, or fine up to ₹5 lakh, or both.
s.66C	Identity theft / fraudulent use of another person's electronic signature, password or unique identification feature.	Up to 3 years' imprisonment and fine up to ₹1 lakh.
s.66D	Cheating by personation using a computer resource.	Up to 3 years' imprisonment and fine up to ₹1 lakh.
s.66E	Violation of privacy through specified capture/transmission of private-area images.	Up to 3 years' imprisonment, or fine up to ₹2 lakh, or both.
s.72	Breach of confidentiality and privacy in the circumstances covered by the section.	Up to 2 years' imprisonment, or fine up to ₹1 lakh, or both.
s.72A	Disclosure of personal information in breach of lawful contract with required intent/knowledge.	Up to 3 years' imprisonment, or fine up to ₹5 lakh, or both.

5.3 Personal-data law: DPDP Act and Rules

The Digital Personal Data Protection Act, 2023 and Digital Personal Data Protection Rules, 2025 are relevant when the university determines the purpose and means of processing digital personal data. The university may be a Data Fiduciary for student/staff data; a cloud or LMS provider may be a Data Processor or another independent fiduciary depending on the facts and contract. A security assessor must not assume that an assessment authorization alone permits unrestricted processing of personal data.

The Rules were notified in November 2025 with phased commencement: Rules 1, 2 and 17–21 commenced on publication; Rule 4 is scheduled one year after publication; Rules 3, 5–16, 22 and 23 are scheduled eighteen months after publication. Therefore, as of 4 November 2026, not all operational

obligations in the Rules are yet in force. The university should track commencement dates and design to the final standard in advance.

5.5 Legal decision for personal-data systems

The student portal, LMS and email may contain personal data. Before any real test, the privacy officer must determine the university's role, the assessor's role, purpose, data categories, lawful basis/processing conditions, data location, processor terms and applicable commencement dates. The test plan should use synthetic data; if live personal data is unavoidable, a documented necessity assessment, explicit controls and legal approval are mandatory. A vulnerability report must not include readable student records.

Conclusion: Indian IT Act provisions apply to unauthorized access and related conduct involving relevant computer resources in India. DPDP obligations apply according to their commencement and the university's data-processing role. Contractual confidentiality, institutional policies and other applicable laws may also apply. CFAA applies only where jurisdictional facts support it.

6. TASK 5 – SCOPE AND RULES OF ENGAGEMENT (4 MARKS)

6.1 Reusable Rules of Engagement (RoE)

RoE field	Default / required content
Engagement ID	Unique ID: UASAP-YYYY-NNN; e.g., UASAP-2026-001.
Purpose	Assess security before the planned university upgrade; state business questions.
Owner	Named system owner and delegated approver; contact details held in restricted register.
Authorized testers	Named internal/external individuals; no substitution without written amendment.
In-scope assets	Asset ID, hostname, IP, URL, environment, owner, data class and vendor dependency.

Out-of-scope assets	All unlisted assets; production databases unless specifically approved; third-party SaaS infrastructure; personal devices; public internet targets.
Window	Approved start/end date, timezone, daily hours and blackout periods.
Permitted methods	Non-destructive configuration review, limited discovery, authenticated checks on test accounts, manual validation in lab, approved low-rate checks.
Prohibited methods	DoS/DDoS, destructive payloads, ransomware, persistence, malware deployment, bulk data extraction, credential harvesting, phishing, social engineering, physical access and lateral movement unless separately approved in a controlled exercise.
Safety controls	Rate limits, monitoring, backups, rollback, emergency contacts and stop conditions.
Evidence	Minimal, masked, encrypted, access-controlled, timestamped and retained only for approved period.
Reporting	Finding template, severity, reproduction summary, impact, remediation, owner and disclosure deadline.
Change control	Any target, tester, method, window or data change requires a signed RoE amendment before execution.

6.2 Asset naming and boundary rule

Each asset receives a unique identifier in the university asset register. Example: UASAP-ASSET-PORTAL-PROD-001. Scope entries must include exact FQDN/IP/URL, environment and owner.

Wildcards are prohibited unless explicitly enumerated and approved. DNS aliases, cloud accounts, shared hosting, CDN endpoints and vendor-managed components must be clarified before testing. A target not matching the approved register is out of scope.

6.3 Authorization verification rules

17. Verify the approver's identity and delegated authority against the university approval register.
18. Confirm that the asset owner has approved the exact asset identifiers and environment.
19. Check the signature, timestamp, engagement ID, version and expiry of the authorization and RoE.
20. Match each tester's legal name or approved identifier to the named tester list.
21. Check that legal/privacy review is complete and any conditions are reflected in the RoE.
22. Re-check authorization at the start of each window and after every scope amendment.
23. Expired, unsigned, ambiguous or conflicting documents result in a 'HOLD – NOT AUTHORIZED' status.

6.4 Testing windows and escalation

Default window: weekdays 20:00–23:00 local time, subject to owner approval and academic calendar blackout dates. This is a planning default, not permission. A service owner may require a different window. Stop immediately if availability degrades, unexpected personal data is exposed, an out-of-scope host is reached, monitoring is lost, or an incident is suspected.

Event	Immediate action	Escalation
Unexpected data exposure	Stop interaction; do not copy further; preserve minimal metadata.	SAGT → Privacy Officer → Legal / Incident Response.
Service instability	Stop test; notify operations; support rollback if directed.	Operations lead → System owner → SAGT.
Out-of-scope target	Stop; do not pivot or enumerate further.	SAGT; obtain signed amendment if needed.
Suspected active compromise	Stop assessment and avoid altering evidence.	Incident Response lead and Legal.
Authorization mismatch	Do not start or continue.	SAGT and approving authority.

7. TASK 6 – AUTHORIZATION AND DISCLOSURE LAYER (5 MARKS)

7.1 Authorization workflow

Step	Action	System status / record
1. Submit	Department submits purpose, assets, data types, requested dates, tester type and business impact.	REQUESTED; request ID generated.
2. Validate	SAGT checks completeness, ownership, asset inventory and conflicts.	INCOMPLETE or IN_REVIEW; deficiencies logged.
3. Owner approval	System owner confirms assets, business window and acceptable risk.	OWNER_APPROVED or REJECTED.
4. Legal/privacy review	Counsel/privacy officer assess legal basis, data, contracts and jurisdiction.	LEGAL_CLEARED, CONDITIONAL or HOLD.
5. RoE approval	Owner, SAGT and tester sign the versioned RoE; external assessor signs NDA/contract.	SIGNED.
6. Final authorization	Delegated authority approves the complete engagement package.	AUTHORIZED with start/end time.
7. Pre-start gate	SAGT checks all conditions and emergency readiness.	READY or BLOCKED.
8. Execute and close	Testing is logged; findings triaged; access revoked and evidence retained/deleted.	ACTIVE → REPORTING → CLOSED.

No verbal approval, chat message or purchase order alone is sufficient. Emergency verbal direction may only be used to stop work or protect services; it cannot expand testing scope.

7.4 Disclosure approach comparison

Approach	Advantages	Risks / suitability
Coordinated disclosure	Balances remediation, user protection and transparency; allows owner/vendor coordination.	Requires active case management and deadlines. Preferred university default.
Full disclosure	Rapid public awareness; can pressure a non-responsive vendor.	May expose users before a fix; can enable exploitation. Exceptional only after legal, privacy and executive review.
Bug bounty	Can attract broad researcher participation and scalable reporting.	Requires mature triage, safe-harbour scope, payment rules, duplicate handling and budget. Not the initial default.

7.5 Disclosure decision rules

24. Use CVD by default for every valid finding.
25. Do not disclose publicly while a finding exposes personal data, credentials, exploitable live details or an unresolved critical risk.
26. Consider a public advisory after remediation is verified, the owner has been notified, sensitive details are removed and legal/privacy review approves.
27. If the owner is unresponsive, escalate internally at the 10-business-day point; set a documented final coordination date based on severity and risk.
28. Full disclosure is an exception requiring written approval by the CIO/delegate, Legal, Privacy and the disclosure coordinator; it must not reveal personal data or facilitate immediate harm.
29. Bug-bounty participation requires a separate published policy defining assets, safe harbour, prohibited tests, reward criteria, disclosure terms and handling of third-party assets.

7.6 Interaction with RoE and legal layer

The authorization ID is linked to the RoE version and legal review. A finding can be disclosed only if it is linked to an authorized engagement or an independently received report handled through the university's vulnerability intake policy. If a finding includes personal data, the privacy officer decides whether the event is also a personal-data breach and whether statutory notifications are required. If a requested retest exceeds the original RoE, a new signed amendment is required.

8. TASK 7 – ISOLATED ETHICAL-HACKING LAB (5 MARKS)

8.1 Lab objective and architecture

The lab demonstrates approved security procedures without touching university production systems. Use a host-only virtual network so the Kali Linux assessment VM and target VM communicate through a private virtual switch that is not routed to the campus network or public internet.

Component	Example configuration	Role
Host computer	VirtualBox/VMware host; patched OS; no bridged adapter for lab VMs.	Runs hypervisor and stores lab snapshots.
Kali Linux VM	2 vCPU, 4 GB RAM, 40 GB disk; host-only NIC 192.168.56.10/24.	Authorized assessor workstation.
Target VM	Intentionally vulnerable training VM or locally built test web app; 192.168.56.20/24.	Authorized target; synthetic data only.
Host-only virtual switch	Private network 192.168.56.0/24; DHCP disabled or controlled.	Isolates VM-to-VM traffic.
Evidence folder	Encrypted local folder; restricted permissions.	Stores configuration, screenshots and lab logs.
Snapshots	Clean baseline and post-experiment snapshots.	Restore repeatable initial state.

Logical connectivity:

Node	Address	Connection

Kali Linux VM	192.168.56.10/24	Host-only adapter → private virtual switch
Target VM	192.168.56.20/24	Host-only adapter → private virtual switch
Host OS	Hypervisor-managed host-only address	Management only; no bridging to campus LAN
Internet / campus network	Not connected to lab segment	No route from the lab; do not enable shared/bridged networking

8.2 Safe configuration record

30. Create a new isolated virtual network named UASAP-LAB-HOSTONLY.
31. Set subnet 192.168.56.0/24; reserve 192.168.56.10 for Kali and 192.168.56.20 for the target.
32. Attach each VM to the host-only adapter only; remove bridged adapters and disable unnecessary shared folders/clipboard.
33. Use synthetic accounts and non-sensitive test data; take a clean snapshot before testing.
34. Record hypervisor version, VM names, OS versions, adapter mode, MAC addresses, IP settings, date/time and snapshot IDs.
35. Verify there is no default route to the campus or public internet from the lab VMs.
36. Save screenshots and command output in the encrypted evidence folder; hash the configuration record if integrity assurance is required.

8.3 Verification operations

Operation A – Record lab configuration (run on each VM):

ip addr

ip route

ip link

Record output and verify the Kali and target interfaces use the expected 192.168.56.x addresses. The route table should not contain an unintended default route through the lab interface.

Operation B – Verify connectivity (from Kali to the intentionally configured target):

ping -c 4 192.168.56.20

Expected result: four replies if ICMP is enabled. If ICMP is disabled, record that fact and use the target's approved local service check instead. Connectivity is not permission to test any other host.
Operation C – Confirm containment:
ip route

Expected result: only the host-only subnet route for the lab interface and no unintended route to production or the public internet. A second check is to inspect the hypervisor network settings and confirm the adapter is Host-only, not Bridged.

9. TASK 8 – REUSABLE DOCUMENT LIBRARY (4 MARKS)

The document library uses version-controlled templates. Each record carries an engagement ID, owner, date, version and access classification. The four core documents below are minimum reusable artefacts; the fifth is included to make disclosure and closure operational.

9.1 Document A – Engagement Request and Authorization Form

Field	Type / default	Validation
Engagement ID	Generated UASAP-YYYY-NNN	Unique; cannot be blank.
Requester / department	Text	Institutional identity required.
Purpose and business justification	Text	Minimum 30 characters; clear outcome.
Asset IDs / environment	Multi-line list	Must match asset register; no wildcard unless approved.
Data categories	Select: public/internal/confidential/personal/special category	Must be selected; privacy review triggered for personal data.
Testers	Named list	All identities verified; external status flagged.

Requested window	Start/end datetime	End must be after start; within approved calendar.
Owner approval	Name, role, signature, timestamp	Required.
Legal/privacy review	Cleared / conditional / hold + reference	Required before final approval.
Final approval	Approver, signature, timestamp	Required; expiry recorded.

9.2 Document B – Rules of Engagement

Fields: engagement ID; RoE version; objective; asset ID and exact locator; environment; included/excluded targets; named testers; source IPs; testing dates and timezone; permitted methods; prohibited methods; rate limits; data handling; monitoring; rollback; emergency contacts; stop conditions; reporting route; signatures; amendment history.

9.3 Document C – Finding and Vulnerability Report (structured output)

Field	Format / rule	Integration destination
finding_id	UASAP-F-YYYY-NNN	Disclosure register primary key.
engagement_id / authorization_id	Valid IDs	Authorization and RoE records.
asset_id	Must be in approved scope	Asset register and owner assignment.
title / summary	Short text; no personal data	Dashboard and executive summary.
severity	Critical / High / Medium / Low / Informational	Triage and remediation SLA.
evidence_reference	Encrypted repository pointer; not raw student data	Evidence vault.
impact	Confidentiality / integrity / availability	Risk register.

reproduction_summary	Minimal safe steps; no destructive payload	Authorized retest plan.
recommended_fix	Actionable remediation	System owner task.
reported_at / due_date / status	ISO date; status enum	Disclosure timeline and audit log.
disclosure_decision	CVD / hold / public advisory approved	Disclosure coordinator.

Example structured record (JSON):


```
{
  "finding_id": "UASAP-F-2026-001",
  "engagement_id": "UASAP-2026-001",
  "authorization_id": "AUTH-2026-001",
  "asset_id": "UASAP-ASSET-LMS-TEST-001",
  "title": "Insufficient access-control check in test environment",
  "severity": "High",
  "impact": ["Confidentiality"],
  "evidence_reference": "vault://UASAP-2026-001/F-001",
  "status": "TRIAGED",
  "reported_at": "2026-11-04",
  "remediation_due": "2026-12-04",
  "disclosure_decision": "COORDINATED"
}
```


Integration rule: a report is accepted only if its engagement and authorization IDs are active, its asset ID is in the approved scope, severity is a valid enum and evidence is stored in the approved vault. The disclosure register receives the finding ID, owner, severity, due date and status.

9.4 Document D – Pre-engagement Checklist

Derived from the RoE in Task 5. It contains the mandatory checks listed in section 6.5 and is signed by the SAGT coordinator before status READY.

9.5 Document E – Coordinated Disclosure and Closure Record

Fields: finding ID; reporter contact; date received; acknowledgement date; triage result; severity; owner notification; remediation plan; agreed deadline; extension rationale; retest result; public advisory decision; privacy/legal approvals; final closure date; evidence deletion date; lessons learned.

10. TASK 9 – INTEGRATE, TEST AND REFINE THE FRAMEWORK (4 MARKS)

10.1 Integrated lifecycle

Request → identity/ownership validation → authorization → legal/privacy review → signed RoE → threat-based plan → isolated-lab rehearsal → READY gate → controlled assessment → finding validation → coordinated disclosure → remediation → retest → closure → programme review.

10.2 Walkthrough: LMS access-control assessment

Time / step	Action	Evidence / gate
Day -10: Request	LMS owner requests an assessment of the LMS test tenant before upgrade.	UASAP-2026-001 created; purpose and asset ID recorded.
Day -8: Approval	Owner and delegated approver sign authorization; named internal tester listed.	AUTH-2026-001; tester and date range verified.
Day -7: Legal/privacy	Privacy officer confirms synthetic student data in test tenant; counsel reviews vendor contract and scope.	LEGAL-CLEARED with no production data condition.
Day -6: RoE	SAGT records test URL, source IP, test account, approved low-impact methods, exclusions and stop contacts.	RoE v1.0 signed.
Day -5: Lab	Kali and target VM configured on host-only 192.168.56.0/24; connectivity and route table recorded.	Lab record LAB-001; no route to production.

Day 1: READY	Checklist confirms all approvals, monitoring, rollback and contact tests.	Status READY → ACTIVE.
Day 1: Test	Assessor validates a simulated access-control weakness using synthetic accounts in the test tenant.	Minimal evidence; no bulk data collection.
Day 1: Finding	Finding UASAP-F-2026-001 created; severity High; asset and authorization IDs match.	Structured report passes validation.
Day 2: Disclosure	SAGT privately notifies LMS owner and sets a remediation plan.	CVD status OPEN; owner and due date logged.
Day 12: Fix	Owner applies access-control fix and requests retest.	Change reference and fix evidence attached.
Day 13: Retest	Authorized assessor confirms test case no longer reproduces.	Retest PASS; finding CLOSED after approval.
Day 14: Close	Temporary access revoked; evidence retention/deletion dates recorded; lessons reviewed.	Closure record and audit trail complete.

11. TASK 10 – SCALABILITY AND GOVERNANCE EVALUATION (4 MARKS)

The following is a reproducible planning simulation, not measured production telemetry. It uses explicit assumptions to compare a small department programme with a university-wide programme. The measures illustrate expected process load and identify where automation or delegated approvals are needed.

11.1 Evaluation scenarios

Measure	Small programme	Large programme
Coverage	1 department; 20 systems; 50 staff.	Whole university; 250 systems; 600 staff (planning scenario).
Assessors	2 internal testers.	8 internal testers + 4 external assessors.
Engagements per quarter	2	12
Approval route	Owner + SAGT + legal/privacy when triggered.	Owner + delegated portfolio approver + SAGT + legal/privacy + vendor review when triggered.
Disclosure volume assumption	5 findings / quarter.	30 findings / quarter.

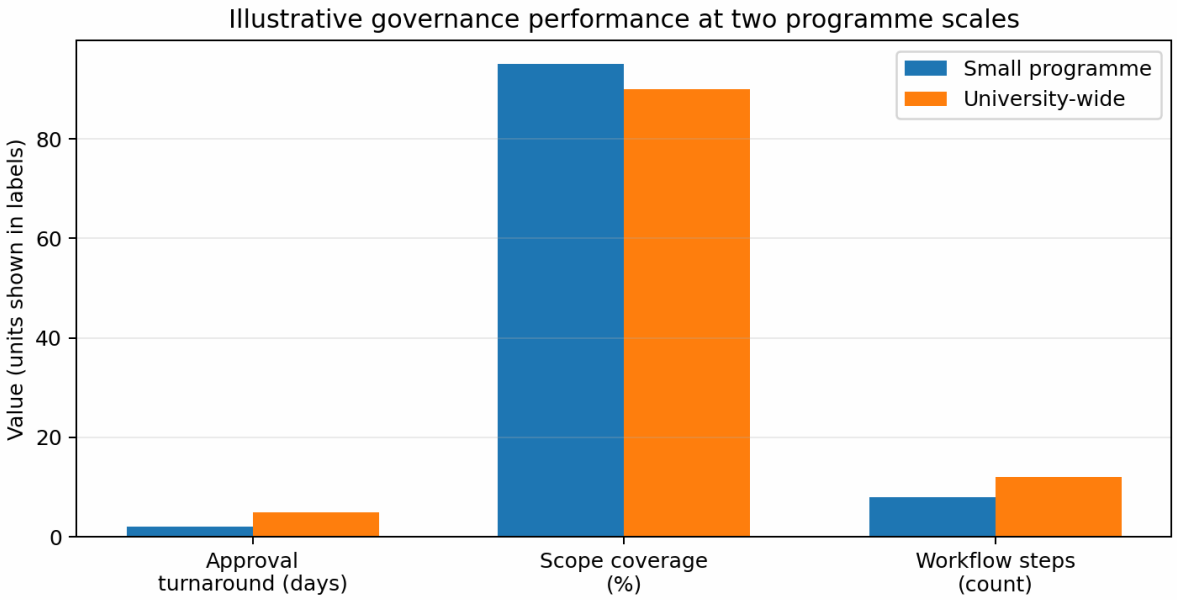


Figure 1. Illustrative small-versus-large programme comparison. Values are planning assumptions, not measured outcomes.

11.3 Interpretation and governance refinements

- Approval turnaround grows from 2 to 5 business days. Introduce delegated approval tiers for low-risk, pre-approved asset groups while keeping legal/privacy review mandatory when triggered.

- Scope coverage drops from 95% to 90%. Establish a central asset register with owner attestations every quarter and automated expiry checks.
- Workflow steps grow from 8 to 12. Use standardized templates, role-based queues and automatic status notifications rather than removing substantive approvals.
- Finding volume grows sixfold under the planning scenario. Create severity-based triage queues and backup finding owners; critical findings page the on-call security lead.

11.4 Reproducible evaluation method

For an actual pilot, record each engagement's request timestamp, authorization timestamp, READY timestamp, asset count planned/verified, number of workflow transitions, finding count, triage timestamp and closure timestamp. Calculate median approval time = median(authorization timestamp − request timestamp); scope coverage = verified in-scope assets ÷ planned in-scope assets × 100; workflow steps = count of recorded state transitions. Repeat quarterly and compare by department, risk tier and internal/external assessor.

Refinement decision: scale through central standards and delegated low-risk approvals, not through blanket permission. High-risk systems, personal-data processing, third-party infrastructure and any exception remain subject to full review.

12. TASK 11 – DEFEND THE FRAMEWORK UNDER A CHANGED REQUIREMENT (4 MARKS)

Changed requirement: continuous and third-party assessments, stricter data-protection rules and a shorter disclosure timeline, while keeping the framework easy to govern and extend.

12.1 Retain, modify, replace or redesign

Component	Decision	Revised design
Authorization	Modify	Introduce standing programme authorization for a defined asset portfolio, but each test window and activity still requires a signed work order and scope token.

Scope / RoE	Redesign	Versioned machine-readable scope manifest; exact assets, assessor identity, method, time window, data class and expiry.
Legal/privacy	Strengthen	Mandatory data-protection impact screen, vendor/subprocessor review, location check and evidence minimization before every new data category or third party.
Threat model	Retain + update	Quarterly threat review and event-triggered update for new vendors, systems and threat intelligence.
Lab	Extend	Repeatable lab images, automated host-only configuration checks and a clean snapshot before each test.
Disclosure	Modify	Shorter internal target: acknowledge within 1 business day; triage within 2 business days; owner plan within 5 business days; high/critical remediation target 15 calendar days or approved mitigation.
Document library	Redesign	Central versioned templates and structured JSON records with mandatory fields and audit trail.

Evaluation	Strengthen	Continuous dashboard for authorization expiry, scope drift, finding SLA, third-party access and data retention.

12.2 New component – Continuous Assessment Control Plane

The Continuous Assessment Control Plane (CACP) is a governance service that coordinates recurring assessments without granting open-ended access.

CACP function	Operation	Integration
Portfolio register	Stores approved assets, owner, data class, vendor and risk tier.	Feeds scope manifest and threat model.
Time-limited authorization token	Creates a signed token for named tester, approved target, method and short test window.	Derived from master authorization + current RoE.
Pre-flight policy check	Checks token expiry, scope match, legal/privacy conditions, maintenance window and monitoring.	Blocks assessment if any gate fails.
Data guardrail	Requires synthetic/masked evidence by default; flags personal-data handling.	Privacy officer approval and evidence vault.
Finding SLA clock	Starts acknowledgement/triage/remediation timers based on severity.	Disclosure register and escalation workflow.
Third-party assurance	Checks contract, named personnel, subprocessor, insurance/indemnity where appropriate, access expiry and deletion certificate.	Vendor register and legal review.

Audit and revocation	Logs every token, action, change and revocation; revokes on expiry or stop-work.	Central audit log and incident response.

12.3 Shortened disclosure timeline

Severity	Acknowledge	Triage	Owner plan	Target fix / mitigation
Critical	Within 4 hours	Within 1 business day	Within 2 business days	Mitigate immediately; target 7 calendar days.
High	Within 1 business day	Within 2 business days	Within 3 business days	Target 15 calendar days.
Medium	Within 1 business day	Within 5 business days	Within 7 business days	Target 30 calendar days.
Low / Informational	Within 2 business days	Within 10 business days	Within 15 business days	Target 60 calendar days or planned release.

These are proposed university service levels, not statutory deadlines. If a legal notification deadline is shorter, the legal deadline prevails. Any extension requires documented risk acceptance, compensating controls and approval by the appropriate authority.

12.4 Evidence-based defence

- Walkthrough evidence: the READY gate blocked missing authorization, out-of-scope assets and missing privacy review; this directly supports continuous pre-flight policy checks.
- Scalability evidence: the planning comparison showed approval time rising from 2 to 5 days and scope coverage falling from 95% to 90%; CACP centralizes inventory and automates expiry/scope checks.

- Legal mapping: Indian IT Act controls require permission and careful data handling; DPDP obligations are phased and must be tracked; third-party processing requires contractual and security controls.
- Disclosure design: severity-linked timelines create predictable remediation accountability; the revised clock shortens response while retaining coordinated disclosure.

12.5 Remaining trade-offs and future improvements

Trade-off / limitation	Why it remains	Future improvement
Automation versus human judgement	Automated scope/token checks cannot fully decide legal context, proportionality or business risk.	Keep human legal/privacy approval for sensitive data and high-risk methods; periodically audit automated rules.
Shorter remediation windows versus operational stability	A 7–15 day fix target may conflict with academic calendars, vendor release cycles or complex upgrades.	Use temporary mitigations, risk acceptance with expiry and escalation; track overdue exceptions.
Continuous testing versus system availability	Frequent checks can create alert fatigue or unintended load.	Use rate limits, canary tests, maintenance windows and service-health abort thresholds.
Third-party visibility	University may not control a vendor's infrastructure or subprocessor practices.	Require contract clauses, evidence of controls, independent assurance and clear shared-responsibility mapping.

13. CONCLUSION

The proposed University Authorized Security-Assessment Programme provides a practical, scalable and auditable way to assess university systems. Its central principle is that authorization, legality and appropriateness are separate mandatory gates. The framework defines stakeholders, threat actors, ethical

rules, Indian and comparative legal controls, precise scope, written approvals, coordinated disclosure, a host-only lab, reusable documents, integration tests and scale-up governance.

The walkthrough demonstrates how an LMS test assessment can move from request to closure without using production exploitation in this assignment. The scalability simulation identifies the need for a central asset register, delegated low-risk approvals and automated workflow records. Under the changed requirement, the Continuous Assessment Control Plane adds time-limited authorization, scope-drift checks, third-party assurance and shorter disclosure targets. The remaining risks are managed through human review, risk acceptance, service-health controls and periodic improvement.

14. REFERENCES

- Government of India. The Information Technology Act, 2000 (Act 21 of 2000), India Code. https://www.indiacode.nic.in/indiacode/handle/123456789/1999
- Government of India, Ministry of Electronics and Information Technology. Digital Personal Data Protection Rules, 2025, Gazette of India, G.S.R. 846(E), 13 November 2025. https://www.meity.gov.in/static/uploads/2025/11/53450e6e5dc0bfa85ebd78686cadad39.pdf
- Press Information Bureau, Government of India. DPDP Rules, 2025 Notified, 17 November 2025. https://www.pib.gov.in/PressReleseDetailm.aspx?PRID=2190655
- United States House of Representatives, Office of the Law Revision Counsel. 18 U.S.C. §1030 – Fraud and related activity in connection with computers. https://uscode.house.gov/view.xhtml?req=granuleid:USC-prelim-title18-section1030
- Computer Emergency Response Team – India (CERT-In). Directions under section 70B(6) of the Information Technology Act, 2000, 28 April 2022. https://www.cert-in.org.in/
- ISO/IEC 27001:2022. Information security management systems – Requirements. International Organization for Standardization.
- ISO/IEC 27002:2022. Information security controls. International Organization for Standardization.
- National Institute of Standards and Technology. SP 800-115, Technical Guide to Information Security Testing and Assessment, 2008. https://csrc.nist.gov/pubs/sp/800/115/final